PERURI
SECURITY PAPER MILL

Dokumen teknis · versi 1.0

Dokumentasi Teknis SI_WOPPIT

Sistem Informasi Work Order Permohonan Perbaikan IT

Analisis arsitektur dan spesifikasi sistem untuk PT Kertas Padalarang, Peruri Group.

Versi dokumen	Formulir acuan	Basis data
1.0	**IT-FR-01/REV00**	**db_cisptkp**

Daftar isi

Dokumen	Analisis Arsitektur & Spesifikasi Sistem
Target aplikasi	SI_WOPPIT (db_cisptkp / CIS PT Kertas Padalarang - Peruri Group)
Peran penyusun	Lead Software Architect & Systems Analyst
Versi dokumen	1.0

1 Ringkasan Sistem 3
1.1 Deskripsi Singkat 3
1.2 Latar Belakang Masalah 3
1.3 Tujuan Utama Pengembangan 4
1.4 Target Pengguna 4
1.5 Batasan Ruang Lingkup 4

2 Hak Akses & Manajemen Peran 5
2.1 Daftar Peran (Roles) 5
2.2 Matriks Hak Akses (Access Control List / CRUD) 5

3 Alur Kerja & Perilaku Sistem 7
3.1 Usecase Analysis 7
3.2 State Flow & Business Process Flowchart 9

4 Arsitektur & Struktur Database 10
4.1 Diagram Entitas (Entity-Relationship Diagram) 10
4.2 Spesifikasi Skema Tabel 11

5 Catatan Teknis & Rekomendasi Arsitektur 13
5.1 Temuan Celah Keamanan (Security Gaps) 13
5.2 Redundansi Data & Race Condition 14
5.3 Rekomendasi Peningkatan Arsitektur & Kinerja 15

01

Ringkasan Sistem

Gambaran umum SI_WOPPIT: apa yang dibangun, mengapa dibangun, dan untuk siapa.

3	6	3	4
Peran pengguna: Administrator, Teknisi IT, User	Tabel basis data inti	Status siklus hidup work order	Opsi hasil pemeriksaan teknisi

1.1 Deskripsi Singkat

SI_WOPPIT (Sistem Informasi Work Order Permohonan Perbaikan IT) adalah aplikasi manajemen tiket perbaikan (service desk / maintenance work order) berbasis web yang dirancang untuk mengelola siklus hidup permintaan perbaikan aset dan perangkat keras/lunak komputer, periferal, serta jaringan kerja di lingkungan PT Kertas Padalarang (anak perusahaan Perum Percetakan Uang Republik Indonesia / PERURI).

Sistem ini mengacu pada formulir standar mutu **IT-FR-01/REV00 (01 April 2021)** - Form Permohonan Perbaikan Barang IT.

1.2 Latar Belakang Masalah

01
Pencatatan Konvensional & Manual

Permintaan perbaikan perangkat IT sebelumnya dilakukan secara lisan, nota fisik, atau pesan informal yang rawan tercecer dan tidak terdokumentasi dengan baik.

02
Ketiadaan Visibilitas Status Antrean

Pemohon kesulitan mengetahui posisi antrean tiket, apakah sedang menunggu, dalam proses perbaikan, menunggu suku cadang/pihak ketiga, atau telah selesai.

03
Ketiadaan SLA & Pelacakan Kinerja Teknisi

Sulit mengukur kecepatan respons teknisi IT, estimasi durasi penanganan per jenis kerusakan, serta histori kerusakan per unit perangkat keras (hardware history card).

04
Kebutuhan Standardisasi Mutu Perusahaan

Kebutuhan audit operasional internal dan kepatuhan sistem manajemen mutu yang mensyaratkan bukti dokumentasi perbaikan resmi.

1.3 Tujuan Utama Pengembangan

- **Digitalisasi End-to-End:** mengotomatisasi alur permohonan dari tiket masuk, validasi awal, penanganan teknisi, hingga penerbitan laporan serah terima perbaikan.
- **Transparansi Status:** memberikan nomor antrean otomatis (`ITxxx`) dan pelacakan status secara real-time bagi pemohon antar-departemen.
- **Arsip & Pelaporan Digital:** memfasilitasi ekspor dokumen standar ke format cetak fisik, PDF, Word, Excel, dan CSV untuk kebutuhan audit maupun rekapitulasi operasional.
- **Analitik Operasional:** menyajikan dasbor metrik visual mengenai volume kerusakan per departemen dan klasifikasi peralatan guna mitigasi kegagalan infrastruktur di masa mendatang.

1.4 Target Pengguna

Pengguna	Peran dalam sistem
Pegawai / Pemohon (Karyawan Lintas Departemen)	Mengajukan keluhan kerusakan alat dan memantau status pengerjaan tiket.
Staf / Teknisi IT (Seksi IT & Maintenance)	Menerima tiket, menginput estimasi waktu pengerjaan, mencatat hasil diagnosis teknis, dan memperbarui status pengerjaan.
Kepala Bagian / Supervisor IT	Memonitor beban kerja teknisi, menyetujui opsi perbaikan pihak ketiga/penggantian, serta mengevaluasi laporan analitik.
Super Administrator (Sistem IT)	Mengelola master departemen, tipe peralatan, akun pengguna, peran (roles), dan granularitas hak akses (role permissions).

1.5 Batasan Ruang Lingkup

Dalam lingkup (In-Scope)

- Manajemen master data: Pengguna (User), Peran (Roles), Izin (Role Permissions), Departemen, dan Tipe Peralatan.
- Alur tiket Work Order: pendaftaran tiket (autonumber format `ITxxx`), pengunggahan foto bukti kerusakan, penugasan internal, penetapan estimasi waktu, pencatatan hasil pemeriksaan, dan penutupan tiket.
- Dasbor analitik ringkas (rekap jumlah tiket, antrean aktif, dan grafik pesanan per departemen).
- Ekspor laporan berformat multi-ekstensi (Print, PDF, Word, Excel, CSV).

Di luar lingkup (Out-of-Scope)

- Manajemen inventaris stok fisik (spare-parts warehouse management) dan procurement tracking secara mendalam.
- Integrasi SSO (Single Sign-On) berbasis LDAP/Active Directory perusahaan (masih menggunakan autentikasi lokal terpisah).
- Penagihan biaya (cost center charging) antar-unit bisnis.

02

Hak Akses & Manajemen Peran

Model otorisasi berbasis peran yang dievaluasi dinamis dari basis data.

Aplikasi mengimplementasikan model otorisasi **Dynamic Database-Driven Role-Based Access Control (RBAC)** melalui tabel `roles` dan `role_permissions` yang dievaluasi secara dinamis oleh pustaka `libs/ACL.php` pada setiap segmen URL controller/action (`$page/$action`).

2.1 Daftar Peran (Roles)

Role ID: 1

Administrator

Memiliki hak istimewa (full privileges) atas seluruh modul sistem, termasuk konfigurasi keamanan, otorisasi peran, dan audit operasional.

Role ID: 2

Teknisi IT / Operator Unit SMT & IT

Bertanggung jawab memproses tiket work order, memperbarui status pengerjaan, menginput hasil diagnosis fisik, dan mengelola katalog peralatan/departemen.

Role ID: 3

User / Pemohon Departemen

Pengguna operasional dari seluruh departemen yang memiliki otorisasi mengajukan tiket baru, melihat progres tiket miliknya, serta mengelola profil pribadi.

2.2 Matriks Hak Akses (Access Control List / CRUD)

Penuh Hak akses penuh (Allowed) Baca Hanya baca (Read-only) Dilarang Forbidden / HTTP 403

Modul / halaman	Aksi / endpoint	Admin	Teknisi	User	Keterangan aturan bisnis
Autentikasi	`index/login`, `logout`	Penuh	Penuh	Penuh	Public whitelist (dikecualikan dari ACL DB)
Password Manager	`passwordmanager/*`	Penuh	Penuh	Penuh	Permintaan reset & perubahan token via email
Home / Dashboard	`home/index`	Penuh	Penuh	Penuh	Widget statistik & grafik distribusi departemen
Profil Akun	`account/index`, `edit`	Penuh	Penuh	Penuh	Memperbarui profil personal dan sandi

Modul / halaman	Aksi / endpoint	Admin	Teknisi	User	Keterangan aturan bisnis
Work Order (IT)	`work_order/list`	Penuh	Penuh	Penuh	Menampilkan daftar tiket perbaikan
	`work_order/view`	Penuh	Penuh	Penuh	Menampilkan rincian teknis tiket
	`work_order/add`	Penuh	Penuh	Penuh	Mengajukan tiket baru (diberi nomor antrean)
	`work_order/edit`	Penuh	Penuh	Dilarang	Mengubah diagnosis, status pengerjaan, estimasi
	`work_order/editfield`	Penuh	Penuh	Dilarang	Pembaruan instan per kolom (AJAX inline edit)
	`work_order/delete`	Penuh	Dilarang	Dilarang	Pembatalan/penghapusan tiket dari basis data
Master Departemen	`departemen/list`	Penuh	Penuh	Baca	Referensi lokasi asal permohonan
	`departemen/view`	Penuh	Penuh	Baca	Detail departemen
	`departemen/add`	Penuh	Dilarang	Dilarang	Tambah data departemen
	`departemen/edit`	Penuh	Dilarang	Dilarang	Ubah data departemen
	`departemen/delete`	Penuh	Dilarang	Dilarang	Hapus data departemen
Tipe Peralatan	`type_peralatan/list`	Penuh	Penuh	Baca	Referensi kategori hardware/software
	`type_peralatan/view`	Penuh	Penuh	Baca	Detail tipe peralatan
	`type_peralatan/add`	Penuh	Dilarang	Dilarang	Tambah data tipe unit
	`type_peralatan/edit`	Penuh	Dilarang	Dilarang	Ubah data tipe unit
	`type_peralatan/delete`	Penuh	Dilarang	Dilarang	Hapus data tipe unit
Manajemen User	`user/list`, `view`	Penuh	Dilarang	Dilarang	Manajemen akun pegawai internal
	`user/add`, `edit`	Penuh	Dilarang	Dilarang	Registrasi & penugasan peran akun
	`user/delete`	Penuh	Dilarang	Dilarang	Pencabutan akun dari sistem
Role & Permissions	`roles/*`, `role_permissions/*`	Penuh	Dilarang	Dilarang	Konfigurasi granularitas matriks keamanan

03

Alur Kerja & Perilaku Sistem

Siapa melakukan apa, dan bagaimana sebuah tiket berpindah status dari masuk hingga selesai.

3.1 Usecase Analysis



Gambar 1. Aktor dan use case SI_WOPPIT. Pemohon terhubung ke use case 1, 2, 3, 7; Teknisi IT ke 1, 4, 5, 6, 7; Administrator ke 8.

Skenario Utama: Pengajuan & Penyelesaian Work Order

1 Inisiasi permintaan (Pemohon)

- Pemohon masuk ke menu **Work Order → Tambah Work Order**.
- Sistem membangkitkan `nomor_antrian` otomatis berbasis prefix **IT** + 3 digit increment (misal: `IT001`).
- Pemohon mengisi data wajib: Nomor Permintaan, Lokasi Departemen, Seksi, Tipe Peralatan, Nama Peralatan, Kode Peralatan IT, Uraian Kerusakan, dan mengunggah Foto Kerusakan.
- Sistem mencatat timestamp (`tanggal_masuk`, `jam_masuk`), menetapkan status awal "Menunggu Antrian", dan menyimpan identitas pemohon (`id_user`).

2 Diagnosis & penanganan (Teknisi IT)

- Teknisi membuka daftar antrean, memeriksa rincian tiket, dan mengubah status menjadi "Proses".
- Sistem mencatat `tgl_proses` dan `jam_proses`.
- Teknisi menginput `estimasi_waktu` pengerjaan, `catatan_it`, serta `hasil_periksa` dengan salah satu opsi: **Dapat diperbaiki**, **Perbaikan ke pihak ketiga**, **Penggantian**, atau **Tidak dapat diperbaiki**.

3 Penyelesaian & serah terima

- Setelah penanganan selesai, teknisi mengubah status menjadi "Selesai" dan sistem menetapkan `tanggal_selesai`.
- Tiket dapat diekspor/dicetak menjadi lembar form fisik resmi **IT-FR-01/REV00** untuk ditandatangani oleh pemohon dan staf IT.

Skenario Alternatif / Pengecualian

Skenario A

Perbaikan pihak ketiga

Jika teknisi memilih hasil periksa "Perbaikan ke pihak ketiga", status WO tetap "Proses" dengan catatan detail vendor pada `catatan_it` hingga barang kembali dan diuji ulang.

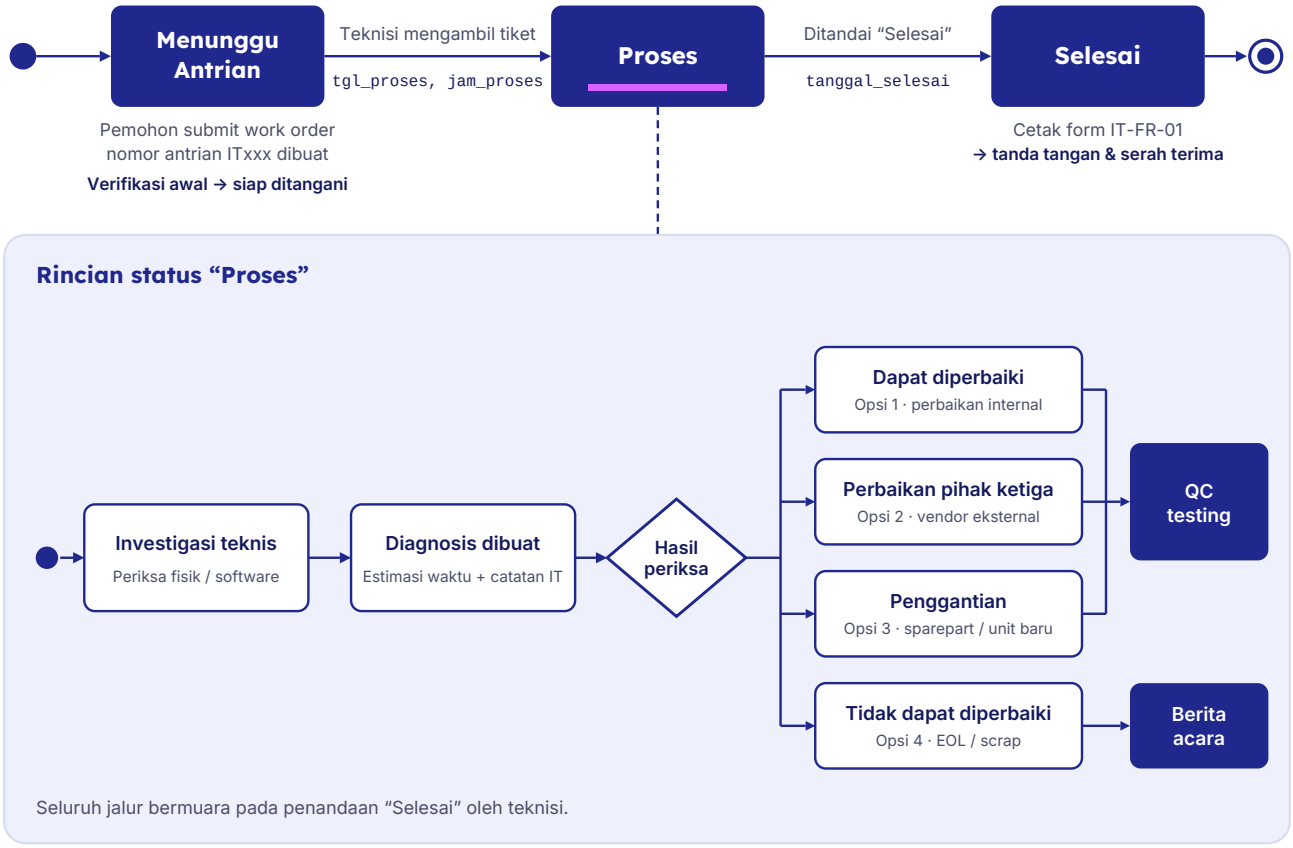
Skenario B

Alat tidak dapat diperbaiki

Jika status ditetapkan "Tidak dapat diperbaiki" atau "Penggantian", form dicetak sebagai lampiran disposisi penggantian aset (write-off / pengadaan baru).

3.2 State Flow & Business Process Flowchart

Diagram berikut memetakan transisi status work order dari inisiasi hingga terminasi.



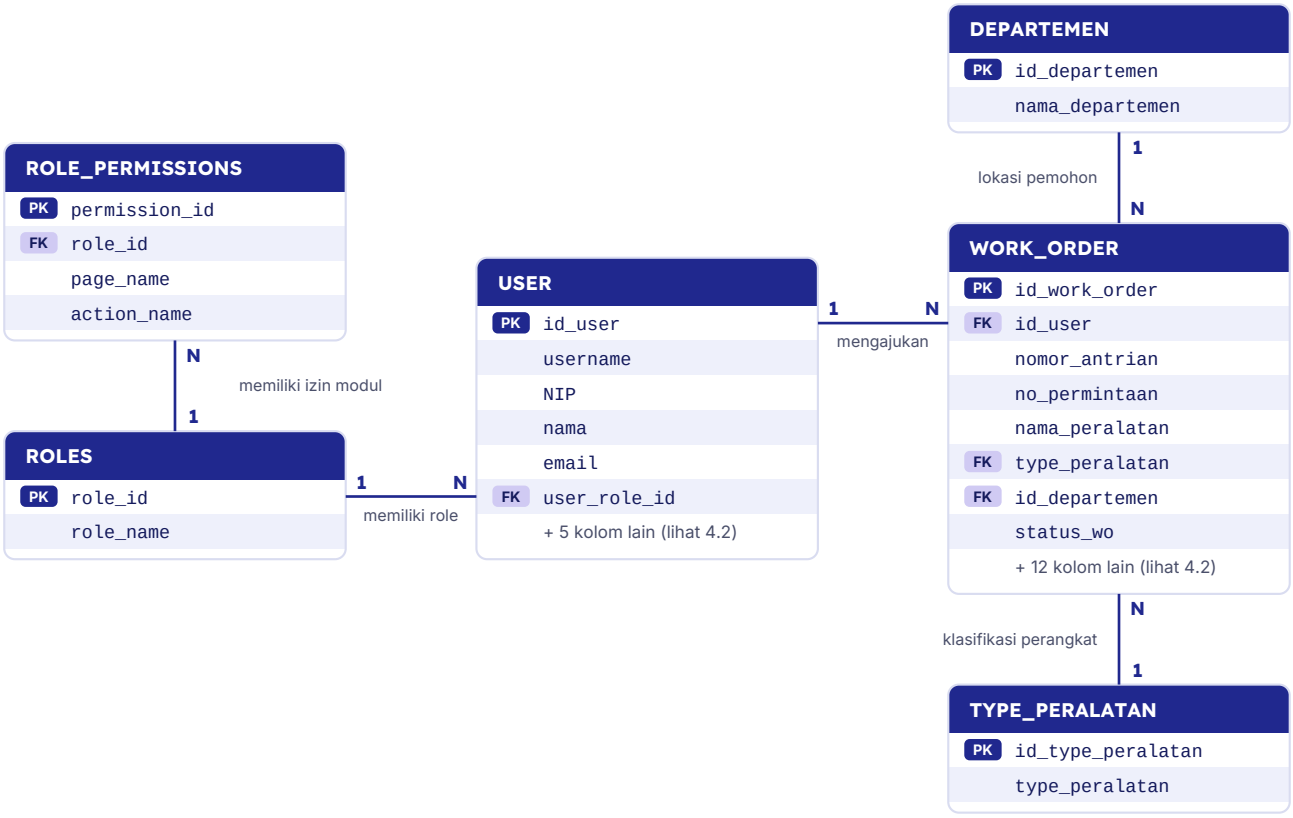
Gambar 2. Transisi status work order: Menunggu Antrian → Proses → Selesai, beserta rincian keputusan pada tahap Proses.

04

Arsitektur & Struktur Database

Aplikasi berinteraksi dengan database relasional MySQL/MariaDB (db_cisptkp).

4.1 Diagram Entitas (Entity-Relationship Diagram)



Gambar 3. ERD SI_WOPPIT. Kolom tambahan pada USER dan WORK_ORDER diuraikan lengkap pada bagian 4.2.

Induk (1)	Anak (N)	Makna relasi
ROLES	USER	memiliki role
ROLES	ROLE_PERMISSIONS	memiliki izin modul
DEPARTEMEN	WORK_ORDER	lokasi pemohon
TYPE_PERALATAN	WORK_ORDER	klasifikasi perangkat
USER	WORK_ORDER	mengajukan

4.2 Spesifikasi Skema Tabel

Tabel `work_order` (entitas transaksional utama)

Menyimpan seluruh data transaksional tiket keluhan dan status pemeliharaan.

Nama kolom	Tipe data	Constraint	Deskripsi & aturan bisnis
`id_work_order`	`INT(11)`	**PK**, Auto-Inc	Identifikator unik tiket work order
`id_user`	`INT(11)`	**FK** → user.id_user	ID pengguna pemohon tiket
`nomor_antrian`	`VARCHAR(20)`	Not Null, Index	Format kode antrean: IT + 3 digit (mis. IT001)
`no_permintaan`	`VARCHAR(50)`	Not Null	Nomor registrasi surat/memo internal pemohon
`nama_peralatan`	`VARCHAR(100)`	Not Null	Nama/merek peralatan (contoh: PC Lenovo ThinkCentre)
`type_peralatan`	`INT(11)`	**FK** → type_peralatan	Kategori peralatan (Hardware, Printer, Network, dll.)
`id_departemen`	`INT(11)`	**FK** → departemen	Lokasi departemen asal pemohon
`seksi`	`VARCHAR(100)`	Not Null	Unit kerja terkecil dalam departemen
`kode_it`	`VARCHAR(50)`	Not Null	Nomor inventaris/label barcode IT pada unit
`kerusakan`	`TEXT`	Not Null	Deskripsi gejala kerusakan oleh pemohon
`photo`	`VARCHAR(255)`	Not Null	Path/file foto fisik kondisi unit atau screenshot error
`tanggal_masuk`	`DATE`	Not Null	Tanggal tiket disubmit ke sistem
`jam_masuk`	`TIME`	Not Null	Waktu pencatatan tiket masuk
`tgl_proses`	`DATE`	Nullable	Tanggal teknisi memulai tindakan perbaikan
`jam_proses`	`TIME`	Nullable	Waktu teknisi memulai penanganan
`estimasi_waktu`	`VARCHAR(100)`	Nullable	Estimasi durasi penyelesaian (mis. “2 Hari Kerja”)
`hasil_periksa`	`VARCHAR(50)`	Nullable	Nilai: Dapat diperbaiki, Perbaikan ke pihak ketiga, Penggantian, Tidak dapat diperbaiki
`catatan_it`	`TEXT`	Nullable	Uraian teknis tindakan perbaikan / kendala
`status_wo`	`VARCHAR(30)`	Default: Menunggu Antrian	Nilai siklus hidup: Menunggu Antrian, Proses, Selesai
`tanggal_selesai`	`DATE`	Nullable	Tanggal perbaikan dinyatakan rampung

Tabel `user`

Menyimpan kredensial autentikasi dan profil personal karyawan.

Nama kolom	Tipe data	Constraint	Deskripsi
`id_user`	`INT(11)`	**PK**, Auto-Inc	Identifikator unik user
`username`	`VARCHAR(50)`	Unique, Not Null	Kredensial masuk ke sistem
`password`	`VARCHAR(255)`	Not Null	Hash sandi menggunakan algoritma BCRYPT

Nama kolom	Tipe data	Constraint	Deskripsi
`NIP`	`VARCHAR(50)`	Not Null	Nomor Induk Pegawai PT Kertas Padalarang
`nama`	`VARCHAR(100)`	Not Null	Nama lengkap pengguna
`email`	`VARCHAR(100)`	Unique, Not Null	Alamat email dinas untuk pemulihan akun
`photo`	`VARCHAR(255)`	Nullable	Lokasi penyimpanan foto profil avatar
`user_role_id`	`INT(11)`	**FK** → roles.role_id	Peran keamanan yang diberikan pada user
`login_session_key`	`VARCHAR(255)`	Nullable	Token remember-me berbasis cookie
`password_reset_key`	`VARCHAR(255)`	Nullable	Hash token aman untuk reset sandi
`password_expire_date`	`DATETIME`	Nullable	Masa kedaluwarsa reset link (+1 hari)

Tabel pendukung & RBAC

Tabel	Kolom
`roles`	`role_id` (**PK**, INT), `role_name` (VARCHAR(50))
`role_permissions`	`permission_id` (**PK**, INT), `role_id` (**FK**, INT), `page_name` (VARCHAR(50)), `action_name` (VARCHAR(50))
`departemen`	`id_departemen` (**PK**, INT), `nama_departemen` (VARCHAR(100))
`type_peralatan`	`id_type_peralatan` (**PK**, INT), `type_peralatan` (VARCHAR(100))

05

Catatan Teknis & Rekomendasi Arsitektur

Berdasarkan tinjauan mendalam atas source code dan konfigurasi aktif, ditemukan beberapa anomali desain, celah keamanan, dan inefisiensi yang perlu diperbaiki.

5.1 Temuan Celah Keamanan (Security Gaps)

Kritis Temuan 1

Celah eskalasi hak akses (privilege escalation via mass assignment)

Lokasi temuan
`app/controllers/AccountController.php` (baris 53) dan `app/views/partials/account/edit.php` (baris 103-130).

Kerentanan
Form profil memuat input `user_role_id` yang hanya disembunyikan menggunakan atribut HTML `hidden`. Di sisi backend, `AccountController::edit` tetap menerima dan memproses `user_role_id`.

Dampak
Pengguna dengan hak akses biasa (User) dapat mengubah payload HTTP POST saat mengedit profil untuk mengirimkan `user_role_id=1`, secara instan menaikkan hak akses menjadi Administrator.

Rekomendasi remediasi
Hapus `user_role_id` dari array `$fields` yang diizinkan untuk diedit di `AccountController::edit`. Perubahan peran hanya boleh dilakukan oleh Administrator melalui `UserController`.

Peringatan Temuan 2

Manipulasi kepemilikan tiket (IDOR & client-side spoofing)

Lokasi temuan
`app/views/partials/work_order/add.php` (baris 61-72).

Kerentanan
Nilai `id_user` dikirimkan melalui input hidden di browser client (`<input id="ctrl-user" value="<?php echo USER_ID; ?>" name="id_user">`).

Dampak
Penyerang dapat mengganti nilai `id_user` dalam request body untuk membuat tiket atas nama orang lain (identity spoofing).

Rekomendasi remediasi
Tanggalkan parameter `id_user` dari input form POST. Di controller (`Work_orderController::add`), tetapkan nilai `id_user` langsung dari sesi server yang aman:

```
$modeldata['id_user'] = USER_ID;
```

Peringatan Temuan 3

Data exposure pada document root (error.log 246 MB)

Lokasi temuan
File `error.log` (berukuran sekitar 246 MB) berada langsung di root direktori proyek.

Kerentanan
Konfigurasi server web tanpa proteksi ekstensi log memungkinkan siapa pun mengunduh `error.log` via HTTP GET. Log ini berisi rincian query SQL, path direktori server, dan informasi sistem internal.

Rekomendasi remediasi
Pindahkan direktori logging ke luar root web atau tambahkan proteksi deny-all pada `.htaccess`:

```
<FilesMatch "\.(log|sql|ini|env)$">
    Order allow,deny
    Deny from all
</FilesMatch>
```

5.2 Redundansi Data & Race Condition

1. Race condition pada pembangkitan nomor antrean

- Metode `SharedController::antrian_otomatis()` mengambil nomor antrean tertinggi menggunakan `SELECT max(nomor_antrian) FROM work_order` saat halaman Add dimuat.
- Jika dua pengguna membuka form pada waktu yang berdekatan, keduanya akan memperoleh nomor antrean yang sama.

Solusi
Gunakan transaksi database ACID dengan locking (`SELECT ... FOR UPDATE`), atau buatkan Sequence Table terpisah, atau bangkitkan nomor antrean di tingkat database trigger sebelum insert.

2. Redundansi pemanggilan `session_start()` & `config.php`

- File `SharedController.php` dan `home/index.php` memanggil ulang `session_start()` dan `require('config.php')`, padahal `index.php` telah menginisialisasi bootstrap sistem secara global.
- Hal ini memicu ribuan baris `PHP Notice: Constant ... already defined` yang memenuhi file log hingga ratusan megabyte.

Solusi
Bersihkan include ganda tersebut dari controller dan view partials.

5.3 Rekomendasi Peningkatan Arsitektur & Kinerja

Peta jalan peningkatan arsitektur

Sprint 1 · Security Hardening

- Hilangkan `user_role_id` dari `AccountController::edit` (cegah privilege escalation).
- Set `id_user` di sisi backend session pada `Work_orderController::add`.
- Proteksi file log & rotasi log berkala (logrotate / limit max size).

Sprint 2 · Concurrency & Data Integrity

- Perbaiki pembuatan nomor antrean dengan database transaction & lock.
- Pasang indeks komposit pada `(id_departemen, status_wo, tanggal_masuk)`.
- Scoping data tiket: user non-admin hanya dapat melihat tiket departemen/miliknya.

Sprint 3 · Operational & Notification

- Integrasikan notifikasi email/WhatsApp Gateway (status update ke pemohon).
- Standardisasi migrasi skema database menggunakan file versioning (.sql/Phinx).

Indexing & optimasi query

Kolom `work_order.nomor_antrian`, `work_order.id_departemen`, dan `work_order.status_wo` sering digunakan untuk filtering dan grouping pada dasbor analitik. Tambahkan indeks komposit untuk menjaga response time di bawah 100 ms seiring bertambahnya volume record.

Scoping data tiket (data isolation)

Saat ini `Work_orderController::index()` menampilkan seluruh tiket dari semua departemen kepada siapa pun yang memiliki izin akses `work_order/list`. Disarankan menambahkan tenant filtering berbasis role: jika pengguna memiliki role **User**, otomatis tambahkan klausa berikut agar privasi tiket antar-departemen tetap terjaga.

```
$db->where("work_order.id_user", USER_ID);
```